Detecção Avançada com Windows Sysmon

1. Matriz de Eventos Críticos

ID	Evento	Aplicação em Hunting
1	Process Creation	Execuções suspeitas e anomalias de linha de comando.
3	Network Connection	Beacons de C2 e movimentação lateral (Ex: Portas 4444, 8080).
10	Process Access	Acesso à memória do lsass.exe (Dumping de credenciais).
11	File Create	Identificação de artefatos de Ransomware e Droppers.
12/13/14	Registry Event	Persistência via chaves de registro e modificações de segurança.
22	DNS Query	Exfiltração de dados e domínios de Comando e Controle.

2. Metodologia de Hunting via CLI (PowerShell/XPath)

A busca por ameaças é otimizada através de consultas XPath granulares para isolar artefatos de alta fidelidade.

Hunting de Frameworks de Exploração (Metasploit/C2)

Foco em portas de conexão reversa não convencionais:

PowerShell

```
Get-WinEvent -Path ".\Hunting_Metasploit.evtx" -FilterXPath '*/System/EventID=3 and */EventData/Data[@Name="DestinationPort"]=4444'
```

Detecção de Extração de Credenciais (Mimikatz)

Identificação de processos não autorizados acessando o processo LSASS:

PowerShell

```
Get-WinEvent -Path ".\Hunting_Mimikatz.evtx" -FilterXPath '*/System/EventID=10 and
*/EventData/Data[@Name="TargetImage"]="C:\Windows\system32\lsass.exe"'
```

Investigação de RATs (Remote Access Trojans)

Filtro para identificar padrões de beaconing em portas de alto risco:

PowerShell

```
Get-WinEvent -Path ".\Hunting_Rats.evtx" -FilterXPath '*/System/EventID=3 and
*/EventData/Data[@Name="DestinationPort"]=8080'
```

3. Estratégias de Configuração (XML)

A redução de ruído é alcançada através de regras de exclusão para processos conhecidos e inclusão para alvos críticos.

- **Mimikatz:** Excluir svchost.exe de acessos ao lsass.exe para destacar anomalias.
- **C2/RATs:** Monitorar portas comuns (1034, 1604, 8080) e excluir processos ruidosos como OneDrive.exe.

4. Análise Técnica de Atividade Maliciosa (Resumo)

A eficácia da detecção baseia-se na correlação de eventos. No cenário de **Ransomware**, monitoramos a criação de arquivos (ID 11) com nomes de notas de resgate. No caso de **Mimikatz**, focamos no GrantedAccess do processo ID 10 para validar o dump de memória. Para **RATs e C2**, a investigação não se limita à porta, mas à análise de **Beaconing**, onde a frequência das conexões (campo TimeCreated) revela o automatismo da comunicação maliciosa. O analista deve evitar o uso cego de templates de mercado, garantindo visibilidade em portas comuns (como 53 e 80) que são frequentemente sequestradas para evasão.

Esta seção da sua documentação é vital para demonstrar conhecimento em **Forense e Resposta a Incidentes**, pois aborda como os atacantes garantem que não serão expulsos da rede (Persistência) e como tentam se esconder (Evasão).

Abaixo, o Markdown técnico condensado e sem imagens, conforme solicitado, mantendo o foco em **metodologia e comandos**.

Persistência e Técnicas de Evasão em Ambientes Windows

Este relatório descreve as táticas utilizadas por adversários para manter o acesso ao sistema comprometido e as técnicas de ocultação de artefatos maliciosos através do Sysmon e PowerShell.

1. Mecanismos de Persistência

A. Pastas de Inicialização (Startup) - ID 11

Atacantes frequentemente inserem executáveis maliciosos em diretórios de inicialização automática. O monitoramento de `\Start Menu` ou `\Startup\` é crítico.

- **Identificado:** Criação do arquivo `persist.exe` em diretórios de inicialização.
- **Regra de Hunting (RuleName T1023):** Monitora a criação de arquivos em locais de boot automático.

B. Chaves de Registro (Run Keys) - IDs 12, 13, 14

A modificação de chaves como `CurrentVersion\Run` permite que um malware seja executado a cada logon.

- **Evidência:** Adição do valor `Persistence` apontando para `%windir%\System32\malicious.exe` no registro `HKLM`.
- **Query de Investigação:**

PowerShell

Busca por modificações em chaves de Run via PowerShell

Get-WinEvent -Path ".\T1060.evtx" -FilterXPath '*/System/EventID=13'

2. Técnicas de Evasão de Defesa

A. Fluxos de Dados Alternativos (ADS) - ID 15

O NTFS permite anexar dados a arquivos em fluxos ocultos (`$DATA`). Malwares utilizam isso para esconder binários dentro de arquivos legítimos.

- **Comando Forense:** `dir /r` é utilizado para listar fluxos ocultos em um diretório.
- **Detecção via Sysmon:** O Event ID 15 gera hashes de fluxos recém-criados, permitindo rastrear o conteúdo oculto.

- **Exemplo:** `not_malicious.exe:malware:$DATA` (Onde o conteúdo malicioso está oculto no fluxo "malware").

B. Injeção de Código e Remote Threads - ID 8

Técnicas como **Process Hollowing** ou **Injeção de PE Reflexiva** utilizam a API `CreateRemoteThread` para executar código dentro de um processo legítimo (ex: `notepad.exe`).

- **Indicador de Comprometimento (IoC):** `powershell.exe` criando threads remotas em processos de sistema ou editores de texto.
- **Query de Hunting:**

PowerShell

Identifica todas as criações de threads remotas no log

Get-WinEvent -Path ".\Detecting_RemoteThreads.evtx" -FilterXPath '*/System/EventID=8'

3. Análise Metodológica de Resposta

A caça a ameaças (Threat Hunting) nessas categorias exige uma análise de **comportamento anômalo**:

1. **Persistência:** Não basta encontrar o arquivo; deve-se investigar o processo pai (PPID) que realizou a escrita no registro ou na pasta de startup.
2. **Evasão:** O uso de ADS é um forte indicador de intenção maliciosa, raramente utilizado por softwares legítimos em pastas como `Downloads` ou `Temp`.
3. **Injeção:** A correlação do ID 8 com o ID 10 (Process Access) é a técnica mais eficaz para confirmar ataques de injeção de memória de alta complexidade.

Táticas MITRE: Persistence (TA0003) | Defense Evasion (TA0005)

Esta é a seção de **Atividade Prática Final**. Como aqui você irá consolidar todas as investigações com prints, o Markdown abaixo está estruturado para ser o seu **Relatório de Forense Digital**.

Ele organiza os quatro cenários de investigação, destacando os pontos onde as perguntas do laboratório exigem evidências visuais (prints).

Entendido. Essa é uma excelente forma de documentar: você une a **evidência visual** (print) com a **conclusão técnica** (resposta da questão). Isso mostra que você não apenas encontrou o dado, mas sabe exatamente o que ele significa no contexto da investigação.

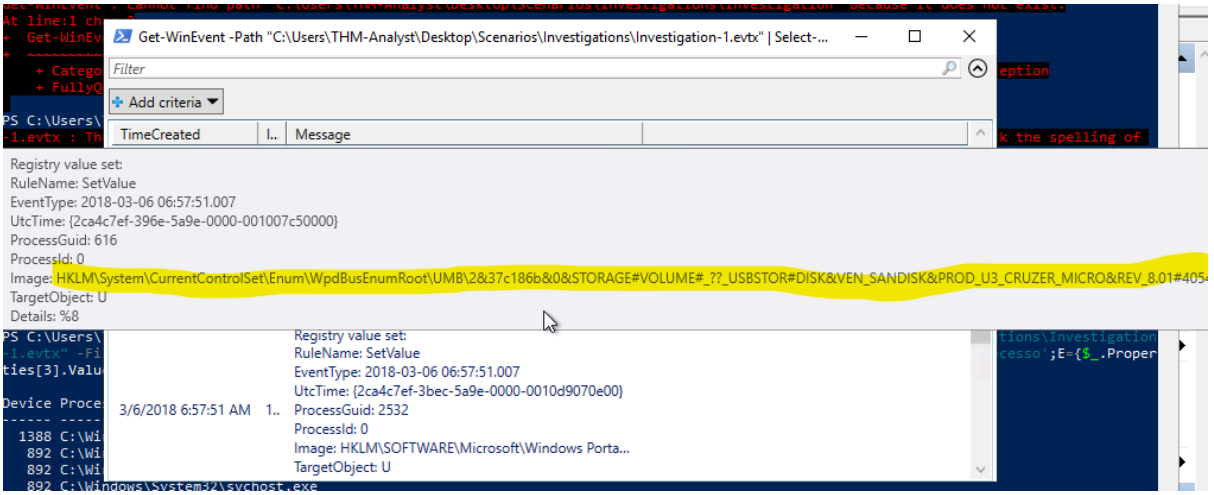
Relatório de Investigações Forenses: Casos Reais

Este documento detalha a resolução de incidentes críticos utilizando análise de logs `.evtx`. Cada seção apresenta a evidência técnica extraída e a conclusão da investigação, referenciando os pontos de controle da auditoria.

Investigação 1: Malware via USB

Cenário: Identificação de infecção originada por hardware externo e execução de processos iniciais.

- **Chave de Registro do Dispositivo:** `HKLM/System/CurrentControlSet/Enum/WpdBusEnumRoot/UMB/2&37c186b&0&STORAGE#VOLUME#_??_USBSTOR#DISK&VEN_SANDISK&PROD_U3_CRUZER_MICRO&REV_8.01#4054910EF19005B3&0#\FriendlyName`
- **Identificação via RawAccessRead:** `\Device\HarddiskVolume3`
- **Primeiro Executável disparado:** `rundll.32.exe`

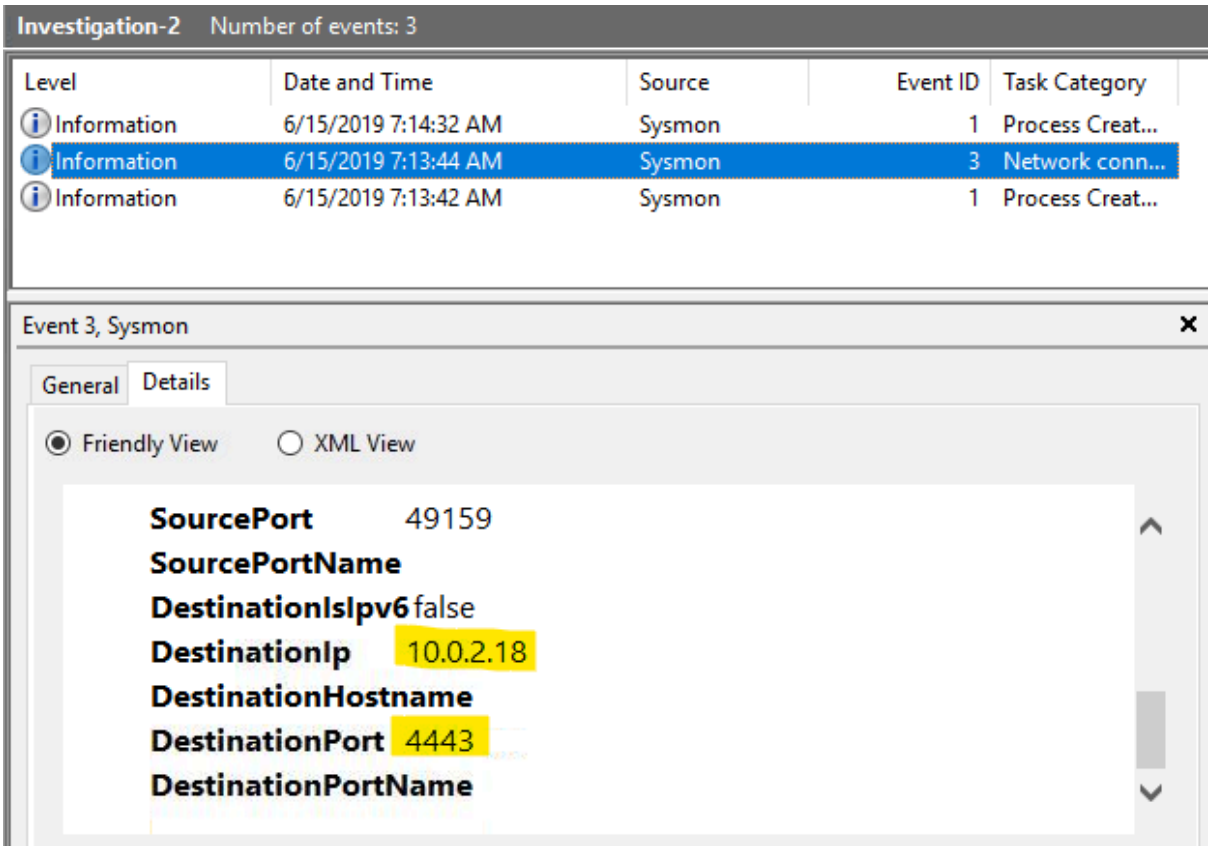


Investigação 2: Mascaramento HTML e C2

Cenário: Execução de payload disfarçado para evasão de antivírus e estabelecimento de conexão reversa.

- **Percurso da Carga Útil (Payload):** `C:\Users\IEUser\AppData\Local\Microsoft\Windows\Temporary Internet Files\Content.IE5\S97WTYG7\update.hta`
- **Arquivo de Mascaramento:** `C:\Users\IEUser\Downloads\update.html`
- **Binário Assinado (LotL):** `C:\Windows\System32\mshta.exe`

- **Indicadores de Rede (C2):** IP: `10[.]0[.]2[.]18` | Porta: `4443`



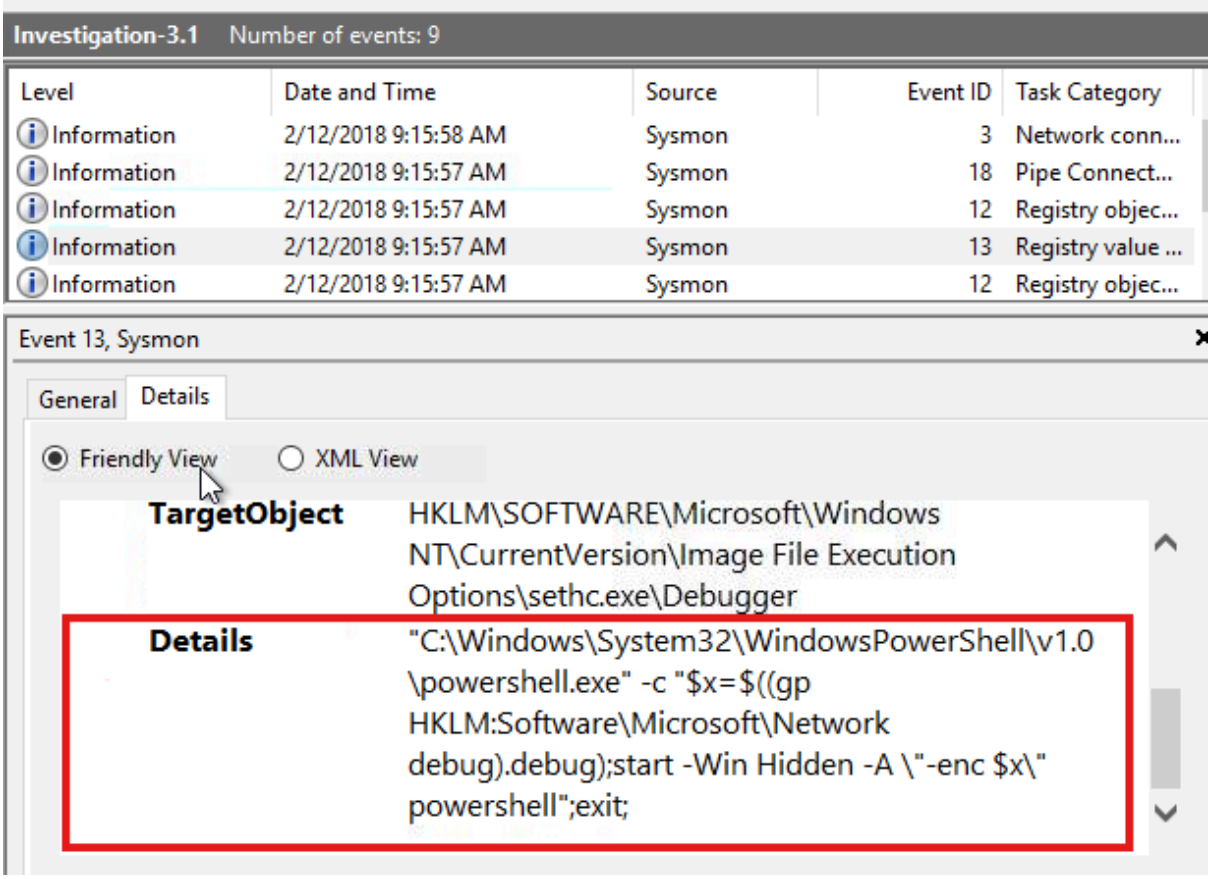
Investigação 3: Persistência (Registro e Agendamento)

Cenário: Análise de métodos para manutenção de acesso e movimentação lateral.

Fase 3.1: Persistência em Registro

- **Infraestrutura:** IP Adversário: `172[.]30[.]1[.]253` | Host Afetado: `DESKTOP-0153T4R`| Servidor C2: `empirec2`
  (Referência: IP do adversário, nome do host do endpoint e nome do host do servidor C2)
- **Armazenamento do Payload:** `HKLM\SOFTWARE\Microsoft\Network\debug`
- **Inicialização PowerShell:**
  ```
  "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -c
  "$x=$((gp HKLM:Software\Microsoft\Network debug).debug);start
  ```

```
-Win Hidden -A \"-enc $x\" powershell";exit;
```



Fase 3.2: Tarefas Agendadas

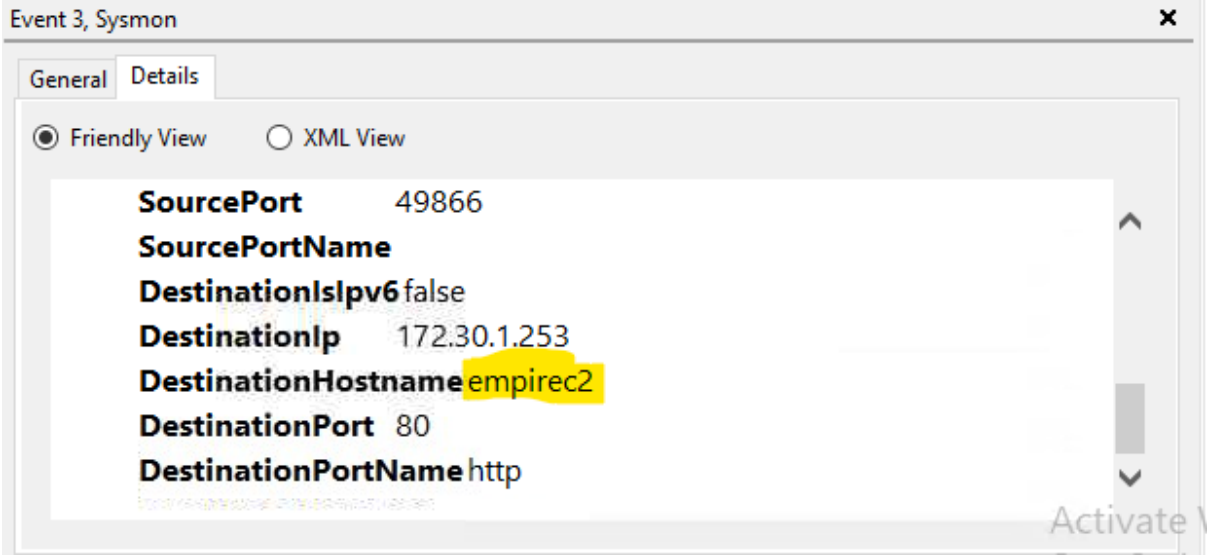
- **Caminho e Comando de Persistência:** `c:\users\q\AppData:blah.txt`
- **Comportamento de Processo Suspeito:** `lsass.exe`

Investigação 4: Infraestrutura de Botnet

Cenário: Identificação de infraestrutura de comando e controle ativo e atribuição de ferramenta.

- **Vetor de Ataque:** IP: `172[.]30[.]1[.]253` | Porta: `80`
  (Referência: Qual é o endereço IP do adversário e em qual porto ele está operando?)

- **Sistema de C2 Identificado:** `Empire`



Conclusão

A investigação demonstrou a eficácia do Sysmon na captura de artefatos que variam desde modificações de baixo nível no registro até comunicações de rede de frameworks de C2 conhecidos. A metodologia aplicada garantiu a reconstrução completa da linha do tempo dos ataques.

Analista Responsável: Cauã

Data da Conclusão: 11 de Março de 2026